

SECURITY DISCLOSURE DOCUMENT

Vishal Gold App — Residual Risk Disclosure & Client Action Register

Project	Vishal Gold — B2B/B2C Jewelry App
Prepared For	Vishal Gold Management / CTO
Prepared By	Senior Android VAPT Expert
Version	v1.0
Date	February 25, 2026

Table of Contents

1. Purpose & Scope
2. Security Work Completed
3. Residual Risks — Client Action Required
4. Risk Acceptance Register
5. Recommended Iteration 2 Actions
6. Authorization & Sign-Off

1. Purpose & Scope

This Security Disclosure Document formally communicates the current security posture of the Vishal Gold Android application to the client's management team. It serves two purposes: to confirm the security remediation work completed prior to delivery, and to transparently disclose any residual security risks that require the client's attention or acceptance before the application is made available to production users.

Security testing was conducted by a Senior Android VAPT Expert against the OWASP Mobile Security Testing Guide (MSTG) and OWASP Mobile Application Security Verification Standard (MASVS). The assessment identified seventeen findings across a spectrum of severity levels. This document summarises what was fixed, what remains, and the specific actions required by the client to achieve an acceptable production security posture.

2. Security Work Completed

The following security findings were identified and fully remediated by the Engineering team within the project scope. These items are considered closed and do not require client action.

ID	Finding	Severity	Resolution Summary
VAPT-001	PII in plaintext SharedPreferences	Critical	Migrated to FlutterSecureStorage with AES-256 encryption
VAPT-003	Hidden admin access via gesture	Critical	GestureDetector and admin navigation function removed
VAPT-004	No client-side OTP rate limiting	High	60-second cooldown on OTP send/resend implemented
VAPT-005	Predictable timestamp-based cart IDs	High	Replaced with cryptographically random UUID v4 values
VAPT-009	PII leaking via debug log statements	Medium	All debugPrint wrapped with kDebugMode compile-time guard
VAPT-016	ADB backup enabled in AndroidManifest	Low	android:allowBackup=false; android:fullBackupContent=false
VAPT-017	Internal exceptions exposed to users	Info	Error messages sanitised to generic strings in production

3. Residual Risks — Client Action Required

The following findings were identified but not fully remediated within the current project scope. Each item includes the risk description, its potential business impact, and the specific action required from the client or a subsequent engineering engagement. These items remain open until the client confirms either remediation or formal risk acceptance.

3.1 VAPT-006 — Firestore Security Rules Not Deployed (HIGH)

The Cloud Firestore database currently operates with open or default security rules, meaning that any authenticated user can potentially read or write any document in the database. This creates a significant risk of unauthorized data manipulation, privilege escalation, and data exfiltration if the application is used by a technically sophisticated party.

Business Impact

Without proper Firestore rules, a Retailer user could theoretically modify a Wholesaler's order, read other users' personal data, or alter product pricing visible only to Wholesalers. This finding represents the highest-priority residual risk and must be addressed before go-live.

Required Client Action

The client's designated technical contact must deploy the security rules provided in the VAPT After Report (document VAPT_Report_After.md) to the Firebase Console before the application is opened to any external users. The Engineering team can assist with this deployment as part of a Tier 1 post-delivery support request at no additional charge.

3.2 VAPT-002 — Server-Side Role Validation (HIGH)

While user roles are now stored in encrypted device storage, the server-side enforcement of role-based access control relies entirely on the Firestore security rules described in VAPT-006 above. Until those rules are deployed, a determined user with Firebase Console access could modify their own role document and gain Wholesaler or Admin access.

Required Client Action

Resolved by deploying the Firestore security rules described in VAPT-006. No separate action needed.

3.3 VAPT-013 — Staging Collection Authorization Gate (HIGH)

The staging Firestore collection, used by the admin preview workflow, currently lacks server-side access controls. While server-side validation was added to the application code, a direct API call to Firestore bypassing the app could write to the staging collection. This is also resolved by the Firestore security rules deployment.

Required Client Action

Resolved by deploying the Firestore security rules described in VAPT-006.

3.4 VAPT-008 — No Certificate Pinning (MEDIUM)

The application does not implement certificate pinning, meaning that a sophisticated man-in-the-middle attacker on the same network could intercept unencrypted network traffic if the device trusts a malicious CA certificate. This is a medium risk primarily relevant for enterprise environments with corporate proxies or compromised networks.

Required Client Action

Implement Android Network Security Config pointing to Firebase's CA bundle. This is a recommended Iteration 2 feature. It does not block go-live but should be implemented within 60 days of production launch.

3.5 VAPT-011 — No App Integrity Check (MEDIUM)

The application does not currently verify its own integrity via the Google Play Integrity API. This means a repackaged or tampered version of the app could authenticate with the Firebase backend as if it were a legitimate installation. This risk is mitigated by the Firestore security rules but is not fully eliminated.

Required Client Action

Integrate the flutter_play_integrity package in Iteration 2. Does not block go-live.

3.6 VAPT-007 — google-services.json in Version Control (HIGH — Historical)

It is possible that the google-services.json configuration file was previously committed to a version of the git repository history. While this file does not contain a secret key per se, it exposes the Firebase project identifiers that, combined with overly permissive Firestore rules, could enable API abuse. The combination of VAPT-006 remediation and API key rotation fully mitigates this risk.

Required Client Action

After deploying Firestore security rules, rotate the Android API key in Firebase Console → Project Settings → General → Your apps → Android app → API key. Add google-services.json to .gitignore if not already present.

4. Risk Acceptance Register

The client must formally indicate, for each residual finding, whether they will remediate the issue or formally accept the associated risk. Acceptance of a risk does not eliminate it but documents the client's informed decision regarding the risk.

ID	Finding	Severity	Decision (Remediate / Accept)	Target Date	Authorized By
VAPT-006	Firestore Rules Not Deployed	High			
VAPT-007	google- services.json Exposed	High			
VAPT-008	No Certificate Pinning	Medium			
VAPT-011	No App Integrity Check	Medium			
VAPT-012	No Screenshot Prevention	Medium			
VAPT-014	FCM Token Rotation Missing	Low			
VAPT-015	No Root/Jailbreak Detection	Low			

5. Recommended Iteration 2 Actions

The Engineering team recommends scheduling a focused Iteration 2 security sprint within 60 to 90 days of production go-live to address all Medium-severity residual findings. The following items are prioritized by risk and implementation complexity.

1. Deploy Firestore security rules (VAPT-006) — Priority: IMMEDIATE.
2. Implement certificate pinning via Android Network Security Config (VAPT-008).
3. Add FLAG_SECURE on Cart and Profile screens to prevent screenshots (VAPT-012).
4. Integrate Google Play Integrity API (VAPT-011).

5. Add FCM token refresh listener (VAPT-014).
6. Integrate root detection library flutter_jailbreak_detection (VAPT-015).

Authorization & Sign-Off

The undersigned parties confirm that they have reviewed the contents of this document and agree to its terms and findings.

Name: _____

Signature: _____

Date: _____

VAPT Lead / Security Reviewer | Engineering Delivery Team

Name: _____

Signature: _____

Date: _____

Client CTO / IT Head | Vishal Gold